

数据处理协议（DPA）核心条款摘要

处理目的 · 角色划分 · 子处理器 · 境内存储 · 安全义务

摘要版 · 正式签约以盖章文本为准 · 版本 2026-07-16

置信度说明：本摘要基于积木仓 BlockHub 标准 DPA 模板，适用于 SaaS 与 PaaS 部署模式。具体条款以双方盖章的完整 DPA 为准，本摘要不构成法律约束力。试点客户可参考本摘要进行初步评估，正式签约前需完成合规审查。

1. 摘要效力与适用部署模式

本数据处理协议（DPA）摘要（以下简称“本摘要”）由积木仓 BlockHub（以下简称“平台”）提供，旨在以简洁方式呈现 DPA 核心条款，便于客户快速了解数据处理安排。本摘要仅供信息参考，不替代正式签署的 DPA 文本。正式签约以双方盖章的完整 DPA 为准，本摘要不构成法律约束力。

本摘要适用于积木仓 BlockHub 企业智能应用 PaaS 产品，包括 Web 端与移动端（App）服务，两者受同一份 DPA 约束。平台默认部署于中国境内数据中心，客户数据默认存储于境内。若客户选择境外部署，需另行签署跨境数据传输条款。

平台采用“选型即交付”模式，客户通过配置而非定制化开发完成部署。因此，数据处理活动具有标准化特征，本摘要覆盖所有标准功能的数据处理场景。对于客户自定义的 API 调用或第三方集成，相关数据处理义务由客户与第三方自行约定。

本摘要中涉及的指标（如响应时间、安全措施覆盖率）均基于平台当前版本，实际表现可能因网络环境、数据量等因素而异。客户应在签约前进行试点测试，以验证平台是否满足其合规要求。平台不承诺“绝对安全”或“零事故”，但将尽商业合理努力维护数据安全。

本摘要的适用范围包括：客户作为数据控制者，平台作为数据处理者，处理客户员工或最终用户的个人数据。客户应确保其向平台提供的数据已获得合法授权，包括数据主体的同意（如适用）。平台不承担因客户数据来源不合规引发的法律责任。

本摘要自发布之日起生效，有效期至 DPA 终止或更新。平台可能根据法律法规或服务变化修订本摘要，修订版本将通过官网或邮件通知客户。客户应定期查阅最新版本，持续使用服务视为接受修订。

2. 定义、角色与处理目的

“个人数据”指与已识别或可识别的自然人相关的任何信息，包括但不限于姓名、联系方式、IP 地址、设备标识符、位置数据等。平台仅处理客户为实现服务所必需的数据，不主动收集与服务无关的信息。

“数据处理”指对个人数据进行的任何操作或一系列操作，包括收集、存储、使用、传输、删除等。平台作为数据处理者，仅根据客户的书面指令（通过平台配置或 API 调用）处理数据，不得超出指令范围。

“数据控制者”为客户，决定数据处理的目的是和方式。客户通过平台设置（如用户权限、数据保留策略）行使控制权。平台提供管理控制台，供客户配置数据处理规则，包括数据分类、访问控制、日志记录等。

“数据处理者”为积木仓 BlockHub，按照客户指令处理数据。平台可委托子处理器（详见第 4 章）协助处理，但需确保子处理器遵守同等安全义务。平台对子处理器的行为承担连带责任，除非法律法规另有规定。

处理目的限于：提供、维护和改进积木仓 BlockHub 服务；处理客户技术支持请求；检测和防止欺诈、滥用或安全威胁；遵守法律义务（如法院命令）。平台不得将客户数据用于自身商业目的，如广告或用户画像。

角色划分以 DPA 签署时的约定为准。若客户同时使用平台的其他产品（如数据分析模块），需确认是否涉及额外数据处理角色。平台建议客户在签约前完成数据保护影响评估（DPIA），以明确自身合规义务。

3. 数据类别与处理活动

平台处理的数据类别包括：客户管理员账户信息（姓名、邮箱、电话号码）；最终用户账户信息（用户名、密码哈希、角色权限）；使用数据（登录时间、操作日志、API 调用记录）；内容数据（客户通过平台创建、上传或处理的应用数据，如表单、工作流、报告）。

平台不处理特殊类别个人数据（如种族、政治观点、健康信息），除非客户主动上传。若客户上传此类数据，需确保已获得数据主体明确同意，并通知平台以便采取额外保护措施。平台默认不提供特殊数据保护功能，客户需自行评估风险。

处理活动包括：收集（通过注册、API 调用、文件上传）；存储（加密存储于境内服务器）；访问（客户授权用户通过 Web/App 访问）；传输（客户与平台之间通过 HTTPS 加密）；删除（按客户指令或保留期届满后）。

平台提供“空库空列表”初始状态，即客户开通服务时，系统不预置任何数据。所有数据均由客户主动导入或通过 API 生成。这有助于客户从零开始构建合规的数据环境，避免历史数据污染。

客户可通过平台管理控制台查看数据处理活动日志，包括数据访问记录、修改记录和删除记录。日志保留至少 180 天，客户可导出用于审计。平台不监控客户数据内容，仅监控系统性能和安全事件。

若客户需要处理的数据类别超出本摘要范围，应提前与平台协商，签署补充协议。平台保留拒绝处理非法或不合规数据的权利，且不承担因此导致的服务中断责任。

4. 子处理器与变更机制

平台可能委托子处理器（如云基础设施提供商、内容分发网络、邮件服务商）协助处理客户数据。当前子处理器列表详见附录 A，包括：阿里云（境内服务器托管）、腾讯云（CDN 加速）、SendGrid（事务性邮件发送）。平台承诺子处理器均签署 DPA 并遵守不低于本协议的安全标准。

平台定期评估子处理器的安全能力，至少每年一次。评估方式包括审查安全认证（如 ISO 27001）、渗透测试报告、SOC 2 报告等。客户可通过平台合规门户查阅子处理器安全摘要，但具体报告可能因保密协议限制无法完整提供。

平台新增或替换子处理器时，将提前 30 天通过邮件或平台公告通知客户。客户有权在收到通知后 14 天内提出异议。若客户基于合理理由（如子处理器所在国法律风险）反对，平台将协商解决方案，包括停止使用该子处理器或允许客户终止服务。

客户不得直接与子处理器签订协议或提出数据访问要求。所有与子处理器相关的沟通应通过平台进行。平台对子处理器的行为承担全部责任，但客户因子处理器违约遭受的损失，平台仅承担直接损失，且以 DPA 约定的责任上限为限。

子处理器变更不影响本摘要的其他条款。平台建议客户定期查看子处理器列表，并在内部合规流程中更新。若客户对子处理器有特殊要求（如必须使用特定云服务商），需在签约前提出，平台将评估可行性。

平台不委托子处理器处理客户数据的核心功能（如数据加密密钥管理）。密钥由客户自行管理（如使用平台提供的 BYOK 功能），平台无法访问解密后的数据。子处理器仅处理加密后的数据或元数据。

5. 安全措施与违规通知

平台实施组织和技术安全措施保护客户数据，包括但不限于：传输加密（TLS 1.2+）、存储加密（AES-256）、访问控制（基于角色的权限管理）、多因素认证（管理员可选）、入侵检测与防御系统、定期漏洞扫描与渗透测试（至少每季度一次）。

平台已获得 ISO 27001 信息安全管理体系认证（证书编号：XXX），并通过 SOC 2 Type II 审计（报告可应要求提供，需签署 NDA）。安全措施的具体细节属于保密信息，平台可提供安全白皮书供客户评估，但不会公开可能削弱安全性的配置参数。

平台设立安全事件响应团队（CSIRT），负责监控、分析和响应安全事件。客户可通过平台安全公告栏或邮件订阅获取安全更新。平台承诺在确认安全事件后 48 小时内通知客户，通知内容包括事件类型、影响范围、已采取的措施及建议的客户行动。

客户有义务在发现可疑活动时立即通知平台，包括但不限于：异常登录、数据泄露、账户被盗。平台将协助客户调查，但客户需承担因延迟通知导致的损失扩大责任。平台不承担因客户自身安全疏忽（如弱密码、未启用 MFA）导致的数据泄露责任。

平台定期进行业务连续性演练，确保在灾难发生时能够恢复服务。RPO（恢复点目标）为 1 小时，RTO（恢复时间目标）为 4 小时。这些指标基于内部测试，实际恢复时间可能因事件严重程度而异，不构成服务等级承诺。

安全措施的有效性需客户共同维护。客户应确保其使用的 API 密钥、访问令牌等凭证安全，并定期轮换。平台提供 API 调用日志，客户可监控异常使用模式。平台不承担因客户凭证泄露导致的数据损失。

6. 客户审计权与配合义务

客户有权每年一次（或发生安全事件后额外一次）委托独立第三方审计平台的数据处理活动，审计范围限于本 DPA 相关条款。审计费用由客户承担，且需提前 30 天书面通知平台。平台将配合审计，提供必要的访问权限和文件，但审计不得干扰平台正常运营。

平台可提供 SOC 2 报告或 ISO 27001 证书作为替代审计证据。若客户接受此类报告，则无需进行现场审计。平台建议客户优先采用报告审查方式，以降低双方成本。若客户坚持现场审计，平台有权要求客户签署保密协议并限制审计人员范围。

客户审计权不包括访问平台内部系统或源代码，除非法律法规另有规定。平台可要求客户审计人员具备相关资质（如 CISA、CISSP），并遵守平台的安全规定。审计过程中发现的平台漏洞，客户应立即通知平台，不得公开披露。

客户有义务配合平台的安全调查，包括提供事件相关日志、用户信息等。若客户拒绝配合，平台可能无法及时响应安全事件，相关责任由客户承担。平台对客户配合义务的要求以合理为限，不要求客户提供超出必要范围的信息。

平台保留因客户滥用审计权（如频繁审计、无理要求）而限制审计的权利。客户行使审计权不得违反适用法律，包括数据保护法。若审计涉及跨境数据传输，客户需确保审计方遵守同等数据保护标准。

审计结果仅供客户内部合规使用，客户不得向第三方披露，除非法律要求。平台对审计过程中获取的客户信息保密，仅用于审计目的。审计完成后，平台有权要求客户销毁相关副本。

7. 跨境、保留与删除

平台默认将客户数据存储于中国境内数据中心，不进行跨境传输。若客户需要将数据传输至境外（如使用海外分支机构），需另行签署跨境数据传输协议，并采取适当保障措施（如标准合同条款、数据保护影响评估）。

客户数据保留期限由客户通过平台管理控制台自行设定，默认保留 365 天。客户可随时调整保留策略，但需注意删除后数据不可恢复。平台在保留期届满或客户终止服务后 90 天内删除所有客户数据，包括备份数据。

删除操作采用安全删除方法，包括逻辑删除（标记覆盖）和物理销毁（硬盘消磁或粉碎）。平台提供删除确认报告，客户可要求出具。平台不保留任何客户数据副本，除非法律要求保留（如税务记录），此时平台将通知客户并仅保留必要数据。

客户可在服务期内随时导出数据，格式包括 CSV、JSON、Excel。平台提供 API 支持批量导出，导出频率不限。客户应自行备份重要数据，平台不承担因客户未备份导致的数据丢失责任。

若客户逾期未支付服务费用，平台有权暂停服务，但数据保留至少 30 天。逾期超过 90 天，平台可删除数据，但需提前 14 天通知客户。客户在服务暂停期间仍可导出数据，但需先结清欠款。

平台不因客户终止服务而保留数据用于任何目的，包括统计或产品改进。客户数据删除后，平台将匿名化处理系统日志（去除个人标识），用于安全分析。匿名化后的数据不再视为个人数据。

8. 附录：条款速查表

本附录提供关键条款的快速索引，便于客户在合规审查中快速定位。以下为速查表内容，完整条款以正文为准。

条款 1：摘要效力——本摘要不具法律约束力，正式 DPA 以盖章文本为准。适用部署模式：SaaS/PaaS，默认境内。

条款 2：角色——客户为控制者，平台为处理者。处理目的：提供、维护、改进服务，安全与合规。

条款 3：数据类别——账户信息、使用数据、内容数据。无特殊数据默认处理。处理活动：收集、存储、访问、传输、删除。

条款 4：子处理器——当前列表见附录 A。新增需提前 30 天通知，客户 14 天内可异议。平台承担连带责任。

条款 5：安全措施——TLS 1.2+、AES-256、RBAC、MFA、IDS/IPS、季度渗透测试。ISO 27001 认证，SOC 2 报告。事件通知 48 小时内。

条款 6：审计权——每年一次，费用客户承担。可接受 SOC 2 报告替代。审计需提前 30 天通知，不得干扰运营。

条款 7：跨境——默认境内存储，跨境需另签协议。保留期客户设定，默认 365 天。删除后 90 天内完成。

条款 8：责任限制——平台责任上限为过去 12 个月服务费的 100%，直接损失。客户需确保数据来源合法。

条款 9：适用法律——中华人民共和国法律。争议解决：平台所在地法院。

条款 10：联系信息——数据保护官邮箱：dpo@blockhub.com，响应时间 48 小时。

获取盖章版 / 完整问卷 / 定制差距分析

访问 blockhub.club 信任与合规中心，或预约演示联系客户成功经理。请随附本 PDF 文档编号以便版本核对。